SECCIÓN 7.3

Selección de herramientas y correlación de fuentes

Temas de esta sección:

- Cómo elegir dónde buscar según el tipo de investigación
- Rutas de investigación: endpoint, identidad, web, red, datos y cloud
- Ejemplo práctico: no perder tiempo en la fuente equivocada
- Errores comunes: buscar en la fuente equivocada o confiar en una sola

7.3 | Ruta de investigación según el caso — Parte 1

ENDPOINT

Primero: EDR.

Buscar:
- Process tree y command line
- Archivos creados, hash y ruta
- Conexiones y persistencia
- Usuario involucrado

Apoyo: SIEM, DNS, proxy, correo, ITSM.

IDENTIDAD

Primero: IAM / IdP.

Buscar:
- Login, MFA, dispositivo
- Sesiones y tokens activos
- OAuth apps y permisos
- Actividad posterior al login

Apoyo: cloud apps, DLP, correo, endpoint.

WEB / APP

Primero: WAF y logs de aplicación.

Buscar:
- Request, payload y response code
- Endpoint accedido y sesión
- Usuario y dirección IP

Apoyo: EDR servidor, SIEM, red, DB logs.

7.3 | Ruta de investigación según el caso — Parte 2

RED / DNS

Primero: DNS, proxy, firewall, NDR o SIEM.

Buscar:
- Dominio/IP y acción
- Frecuencia y volumen
- Otros hosts afectados
- Proceso si existe

Apoyo: EDR, TI, inventario.

DATOS / CLOUD

Primero: CASB, DLP, cloud audit logs o app logs.

Buscar:
- Archivo, usuario y volumen
- Destino y sharing
- App cloud y sesión

Apoyo: identidad, endpoint, proxy.

VULNERABILIDAD

Primero: VM/CSPM/WAF/app owner.

Buscar:
- Activo vulnerable y exposición
- CVE y exploitabilidad
- Logs de explotación

Apoyo: EDR, WAF, SIEM, IR.

7.3 | Ejemplo: no perder tiempo en la fuente equivocada

Buscar en la herramienta equivocada puede demorar la respuesta o generar conclusiones pobres:

```
Caso: Possible OAuth abuse

Error común:
Buscar primero en EDR del endpoint.
→ 30 minutos sin encontrar nada útil.

Mejor ruta:
1. Identity Provider
2. Cloud app audit logs
3. OAuth app permissions
4. Mailbox / SharePoint activity
5. Endpoint solo si hay sospecha local
```

Preguntas de análisis:

- ¿Qué fuente muestra consentimiento OAuth?
- ¿Qué fuente muestra permisos y tokens?
- ¿Dónde veo archivos accedidos?
- ¿Cuándo tendría sentido revisar endpoint?

El OAuth abuse vive en identidad y cloud, no en EDR. Empezar por el endpoint puede llevar 30 minutos sin encontrar nada útil, mientras la evidencia clave estaba en el Identity Provider desde el principio.

7.3 | Errores comunes al seleccionar herramientas

Reconocer estos errores mejora la calidad y velocidad de la investigación:

✘ Buscar en una sola fuente

✔ Ninguna herramienta tiene el cuadro completo. Un caso de identidad necesita IdP + cloud + correo. Un caso de endpoint necesita EDR + red + ITSM.

✘ Empezar por EDR en casos de identidad o cloud

✔ Si el vector es OAuth, impossible travel o regla de correo, el EDR del endpoint no tiene esa información. Empezar por el Identity Provider.

✘ Confiar en score sin leer evidencia cruda

✔ Un score de 90/100 orienta, pero no reemplaza leer el process tree, el command line, la ruta y la actividad posterior.

✘ Cerrar porque una herramienta no encontró nada

✔ 'Sin alertas en EDR' puede significar que el EDR no tiene cobertura en ese host, no que no ocurrió nada. Documentar la limitación.

✘ No correlacionar entre herramientas

✔ Una conexión sospechosa en firewall + proceso sin firma en EDR + dominio nuevo en DNS son tres señales débiles que juntas forman una señal fuerte.

✘ Buscar phishing de credenciales en EDR

✔ El phishing de credenciales no genera malware en endpoint. La evidencia está en identidad: login anómalo, dispositivo nuevo, actividad posterior.